datacare. limited

SECURITY · ENGINEERING · ASSURANCE

[logo artwork to be placed here]

WEB
www.datacare.co.ke
EMAIL
info@datacare.co.ke
PHONE
0722 155 752

Production Hardening — Engineering Report

Elimu Pay / FeeTracker — security, reliability & pre-launch remediation

Prepared by	Datacare Limited · info@datacare.co.ke · 0722 155 752
System	Elimu Pay / FeeTracker — multi-tenant school-fee SaaS (Next.js 16 · Prisma/PostgreSQL · Vercel)
Date	11 June 2026
Status	Phases 0–2 complete & verified · delivered via PR #1 (CI green)
Classification	Confidential — for the intended recipient only

1. Executive summary

This engagement hardened the Elimu Pay / FeeTracker platform for a production launch handling real money (M-Pesa) and the personal data of parents and pupils. Work was delivered in three phases, reconciled against both a source-level audit and the prior pre-production penetration test, and verified end-to-end on an isolated local stack. The headline outcome: the platform's most serious latent risk — an **unauthenticated M-Pesa payment webhook** — has been closed, the deployment pipeline can no longer silently destroy data, and an automated quality gate (tests + CI) now protects the fee-matching and billing logic.

Dimension	Before	After
Payment integrity	Anyone could inject M-Pesa payments; any tenant could claim a paybill	Webhook authenticated & rate-limited; paybill made unique
Authentication	2FA bypassable; one-time codes stored in clear	Signed 2FA token; codes stored as bcrypt hashes
Data protection	Sensitive fields could be stored unencrypted, silently	Authenticated encryption; production refuses to run without a key
Deployments	Destructive schema sync on every deploy	Versioned migrations with a safe-fail path
Quality assurance	No tests, no CI	Automated tests + continuous-integration gates

2. Phase 0 — Security criticals

A1 · Unauthenticated M-Pesa payment webhook CRITICAL

The Daraja confirmation endpoint accepted anonymous requests, created payment records and emailed parents — allowing fabricated payments. It now requires a secret token embedded in the registered callback URL, fails closed, and is rate-limited per paybill.

```
// app/api/daraja/confirmation/route.ts — new guard
const expectedToken = process.env.DARAJA_CALLBACK_SECRET
const providedToken = new URL(req.url).searchParams.get('t')
if (!expectedToken || !secureEqual(providedToken, expectedToken)) {
  console.warn('[daraja] Rejected confirmation: invalid or missing callback token')
  return NextResponse.json(ACCEPTED)   // normal shape, but NO writes / emails
}
```

A2 · Forgeable two-factor cookie HIGH

The `ft_2fa` cookie was the literal text `userId:expiry:valid` — trivially forged to bypass 2FA. It is now signed (HMAC-SHA256) and verified in constant time.

```
// lib/check2fa.ts
export function buildTwoFactorCookie(userId, expiry) {
  return `${userId}:${expiry}:${signTwoFactor(userId, expiry)}`   // HMAC signature
}
```

A3 · Encryption without integrity / silent plaintext HIGH

Field encryption used AES-256-CBC (no tamper detection) and fell back to storing plaintext if the key was absent. Replaced with authenticated AES-256-GCM, with backward-compatible reads of existing data and a hard fail in production when the key is missing.

A4 · One-time codes stored in clear MEDIUM

2FA codes are now generated with a cryptographic RNG and persisted only as bcrypt hashes; a database compromise no longer exposes live codes.

A5 · Public debug endpoint removed MEDIUM

A publicly reachable diagnostics route that leaked configuration was deleted.

A6 · Scheduled-job endpoints failed open MEDIUM

Cron routes previously ran for anonymous callers when the secret was unset. They now fail closed behind a shared authorization helper.

3. Phase 1 — Production safety

Deployments could destroy data BLOCKER

The build performed a destructive schema sync on every deploy, and the recorded migration history was far behind the live schema. We moved to versioned migrations and generated a catch-up migration so history fully represents the schema (verified to apply to a clean database with no drift).

```
- "build": "prisma generate && prisma db push --accept-data-loss && next build"
+ "build": "prisma generate && prisma migrate deploy && next build"
```

No startup configuration validation HIGH

A startup validator now fails fast on a missing database URL, weak auth secret, or (in production) a missing encryption key, and the error-monitoring integration is now correctly initialized server-side.

No automated tests or CI BLOCKER

Introduced an automated test suite for the two highest-risk areas — payment matching and fee calculation — including a guard that a payment is never assigned to the wrong pupil, plus a continuous-integration pipeline that gates every change on type-checking, tests and a full build.

Addition	Effect
Automated unit tests	Regression net over fee-matching & fee math (incl. mis-assignment guard)
Continuous integration	Type-check + tests + production build on every change
Log hygiene + error pages	Sensitive tokens no longer logged in production; graceful error/404 pages

4. Phase 2 — Remaining assessment findings

Item	Resolution
Admin area gated only in the browser HIGH	Now enforced server-side; admin panels are unreachable without a session
Two tenants could share a paybill CRITICAL	Database uniqueness constraint added on the paybill
Pre-launch host indexable under wrong address MEDIUM	Preview host excluded from search engines

A number of earlier findings were confirmed already remediated and required no further change. One larger, cross-cutting item (opaque public identifiers) has been deliberately deferred to a dedicated change window, as the data-exposure paths it depended on are already closed.

5. System impact & required operational actions

Several changes alter runtime behaviour and require coordinated configuration before the first production deploy:

- Production now requires a valid encryption key, authentication secret and database URL — the application will not start otherwise.
- Scheduled jobs and the payment webhook each require their new secrets to be configured; M-Pesa callback registration must be re-run once the webhook secret is in place.
- The first deploy requires a one-time migration baseline; duplicate paybills must be removed before the uniqueness constraint is applied. Both are documented in the deployment guide, and a missed step fails safely without data loss.
- The temporary preview address is now excluded from search indexing; the production domain indexes normally after cut-over.

6. Next steps & forward roadmap

The trajectory from here is non-linear and contingent, gated by a set of interlocking dependencies that resolve in approximate — not strict — sequence. The remaining surface decomposes into several concurrent yet partially-coupled workstreams whose ordering is subject to ongoing discovery and stakeholder alignment.

- **Provider-integration enablement.** Operationalizing the automated parent-engagement layer and the inbound-collections rail is predicated on the procurement, credentialing and sandbox-to-production promotion of one or more third-party gateways, the selection of which is itself a function of cost-model, deliverability and regulatory-posture considerations still to be triangulated.
- **Financial-instrument compliance hardening.** The invoicing and revenue-recognition primitives require alignment with the prevailing statutory framework, the precise contours of which depend on entity-level determinations sitting outside the current technical envelope.
- **Billing & monetization orchestration.** Transitioning the subscription lifecycle from its present manually-mediated state toward an automated, self-reconciling posture entails a multi-phase convergence of capture, entitlement, dunning and reconciliation semantics, each with its own failure-mode surface.
- **Identifier-surface remediation (deferred).** A latent, cross-cutting architectural undertaking touching substantially all persistence and routing layers; best actioned within a dedicated change window given its blast radius.
- **Continuous assurance & residual-risk drawdown.** A rolling cadence of verification, accessibility conformance, observability maturation and residual-finding attrition, continuously re-weighted as new telemetry and review feedback materialize.

Net: the path to general availability is directionally clear but operationally complex, with several critical-path items blocked on external and organizational inputs. Concrete sequencing, effort sizing and milestone definition will be established collaboratively in a subsequent scoping pass once the upstream dependencies above are sufficiently de-risked.